{EPITECH}

PAPOTE_

PIRATER UN PROFIL.
COMPRENDRE. SÉCURISER.

< Atelier pratique de cybersécurité />



SUJET D'ATELIER POUR PARENTS

PAPOTE

Le défi

Papote est un petit réseau social entre voisins, mis en ligne un peu trop vite. Un compte appartient à Edward Lalande, l'un des organisateurs de l'atelier. Votre mission : trouver comment remplacer sa photo de profil par une image de votre choix, sans connaître son mot de passe, puis corriger les failles qui ont rendu cette action possible.

L'objectif n'est pas d'apprendre à attaquer des personnes. C'est de comprendre, dans un terrain de jeu isolé, comment une application peut être détournée — et comment la rendre plus sûre.

Ce que vous allez apprendre

- Comprendre les failles : un compte peut être compromis autrement que par le vol du mot de passe.
- Observer une application : repérer un comportement anormal, remonter à sa cause et formuler une hypothèse.
- Utiliser l'IA avec méthode : lui demander des explications et confronter ses réponses à ce que vous observez.
- Corriger : écrire une protection, puis vérifier qu'elle bloque réellement le scénario d'attaque.

Ce que vous allez apprendre

L'IA est autorisée pendant tout l'atelier, mais elle doit rester un mentor, pas un développeur qui fait le travail à votre place. Elle peut aider à comprendre un fichier, expliquer une requête, suggérer des pistes et relire un raisonnement.

Règle essentielle : l'IA ne doit jamais générer le code utilisé directement dans le projet. Les participants doivent comprendre, écrire et assumer leurs propres corrections.

Le dérouulé de l'atelier

1 - Chasse aux failles	**1h15**	Explorer Papote en équipe et documenter les failles permettant de modifier le profil ciblé.
2 - Correctifs	**1h**	Écrire des protections adaptées avec l'aide explicative de l'IA.
3 - Contrôle croisé	**15 min**	Une autre équipe tente de reproduire les attaques après correction.
4 - Débrief	**15-20 min**	Partager les découvertes et les réflexes à retenir à la maison.

PAPOTE

Déroulement détaillé

1 - La chasse aux failles

Chaque équipe démarre sa propre instance de Papote sur son ordinateur. Elle explore le site et cherche les chemins qui pourraient permettre de modifier la photo de profil du compte fictif d'Edward. Pour chaque piste, elle consigne :

- où se situe le problème (page, action ou fonctionnalité) ;
- quel comportement observé permet de suspecter une faille ;
- comment le scénario pourrait être exploité dans le cadre du laboratoire ;
- quels impacts plus larges seraient possibles sur un vrai service.

2 - Les correctifs

L'équipe reprend chaque faille identifiée et propose une correction. Elle écrit elle-même le code. L'IA peut expliquer les principes de protection et commenter le raisonnement, mais la décision technique et l'implémentation restent entre les mains des participants.

3 - Le contrôle croisé

Les équipes échangent leurs versions corrigées. Une autre équipe rejoue les scénarios documentés. Si une attaque fonctionne encore, le correctif doit être revu : une correction n'est validée que par un comportement observable.

Critère de réussite : l'équipe ne doit pas seulement avoir trouvé une faille. Elle doit pouvoir expliquer sa cause, montrer le correctif et démontrer que le scénario ne fonctionne plus.

Préparer son ordinateur

Le projet se lance localement avec Docker. Il n'est pas nécessaire de déployer un serveur public. Docker doit rester actif pendant toute la séance.

1 - Installer Docker

Windows / macOS : installer Docker Desktop et le démarrer. Sous Windows, accepter WSL 2 si proposé. Linux : installer Docker Engine et le plugin Docker Compose.

2 - Ouvrir le dossier du projet

Ouvrir un terminal dans le dossier Papote. Vérifier avec ls (ou dir sous Windows) que les fichiers docker-compose.yml et README.md sont présents.

Démarrer PAPOTE

Exécuter la commande ci-dessous, attendre la fin du démarrage, puis ouvrir http://localhost:3000 dans un navigateur.

docker compose up --build

Le premier lancement peut prendre une à deux minutes. Garder le terminal ouvert : le fermer arrête le site. Après une modification, relancer la commande de démarrage pour reconstruire le projet. Pour arrêter proprement : Ctrl+C dans le terminal.

Cadre, livrables et discussion

Un laboratoire volontairement fermé

- Papote est exécuté en local sur l'ordinateur de chaque équipe, dans Docker.
- Le compte « Edward Lalande » est fictif et sert uniquement de cible pédagogique.
- Aucune donnée réelle ni aucun compte personnel ne doivent être utilisés.
- Les techniques apprises ne doivent jamais être testées sur un service réel sans autorisation explicite. Le rappel du cadre légal ouvre la séance.

Le périmètre est strict : uniquement l'application Papote fournie, sur l'instance locale de l'atelier. Aucun test sur Internet, aucun compte réel, aucun appareil tiers.

Ce que chaque personne/équipe doit restituer

À la fin, chaque équipe remet une courte fiche de synthèse comprenant :

- les failles trouvées, expliquées en langage courant ;
- la manière dont chacune permettait d'atteindre l'objectif de l'atelier ;
- les risques qu'un attaquant pourrait viser au-delà de cet exemple ;
- les corrections apportées et la manière dont elles ont été vérifiées ;
- ce que l'équipe a appris sur l'usage de l'IA.

Questions pour le debrief

- Combien de temps a-t-il fallu pour identifier une première piste exploitable avec l'IA ?
- Qu'est-ce qui vous a le plus surpris dans la manière dont une application peut être détournée ?
- L'IA vous a-t-elle aidés à comprendre, ou parfois induits en erreur ? Comment l'avez-vous vérifié ?
- Quels réflexes retenir pour la famille : mots de passe, liens reçus, photos partagées, mises à jour et méfiance face aux demandes inhabituelles ?